第 15 章練習解答　安全

題號與本章練習題 PDF 一一對應。答案保留成立條件、關鍵推導與必要的反例。

OS15-E01　越界與防禦邊界

1. 需13 bytes，超容量1。reject契約先驗n≤11，否則拒絕；truncate契約copy min(n,11)=11並buf[11]=0，再明確回報截斷。只copy11但不補NUL不能推出合法字串。
2. 不能，NX檢查執行權而非一般寫入邊界。若越界改到相鄰授權資料，沒有執行stack code仍可出錯；須修copy界限。

檢查。 data長與buffer容量、終止字元分開。

OS15-E02　DoS 的 pending slots

1. 對「被接受並佔用 slot」的同一邊界，穩態 Little 定律 L=λW 給出 λ=2000/8=250 個被接受請求／秒。被拒絕的外部請求不計入 λ，因此此值不決定 offered arrival rate。平均佔用也不決定首次滿槽時間；突發時序及容量拒絕會改變瞬時行為。
2. 多個合法user經同NAT共用IP，可能共同分一個quota；對手也可能有多來源。policy需說明key與公平性，不能由有rate limit推定合法使用不受影響。

檢查。 單位是requests/s，不是bytes/s。

OS15-E03　重用 keystream

1. c1=0xB5，c2=0xD5；c1 XOR c2=0x60=m1 XOR m2。s=c1 XOR m1=0xA5；m2=c2 XOR s=0x70。
2. 否，是XOR的結合律與s XOR s=0。錯誤在同keystream重用；底層generator再強也不消除此代數洩漏。

檢查。 此玩具式只演示nonce/keystream重用，非生產加密。

OS15-E04　RSA 的非互質明文

1. c=5^3 mod55=15。15^2 mod55=5；15^4=25；15^8=20；15^{16}=15。27=16+8+2+1，依序15×20 mod55=25，×5 mod55=15，×15 mod55=5，解回m。
2. 模p是0所以冪後仍0；模q用Fermat因5與11互質，ed=1+2×4×10使5^ed≡5 mod11。兩模同餘再用CRT得mod55同餘。不能直接對mod55套需要互質的Euler。

檢查。 正確性證明不證此小RSA具有安全性。

Lin Cing https://github.com/xinhi6716/computer-science-self-study

OS15-E05　MAC、hash 與 replay

1. 對手可換 m′ 並重算 H(m′)。安全 MAC 使未持鑰者難以偽造新內容，但不阻止複製舊的 (m,tag)。以無歧義編碼把 session、m 與唯一 nonce 綁入 MAC，並驗證接收端的新鮮性狀態。
2. 驗 tag 後，以同一 lock 或交易原子地檢查 nonce 為 pending 並改為 used；兩個 thread 只有一個成功。這不保證外部付款恰好一次：去重紀錄與業務效果還需原子提交或可恢復協定，且外部系統必須支援對應契約。

檢查。 nonce消耗與外部副作用exactly-once不是同一結論。

OS15-E06　歷史 TLS 的身分與forward secrecy

1. 不足。簽章有效本身未完成名稱、用途與信任鏈檢查，也未確認目前對端的密鑰能力。驗證正確 Finished 提供對握手逐字稿與 master secret 的證據；應連同信任與協定假設理解，中繼者也可能轉送訊息。
2. 否。題設記錄的 ClientKeyExchange 含 RSA 加密 premaster；static private key 外洩後可解出 premaster，配合公開 random 導出 master 與 traffic keys。此模式不具 forward secrecy，刪除舊 traffic keys 不能彌補。

檢查。 限定RSA key exchange，不把答案套到所有TLS版本或套件。

OS15-E07　Salt 與猜測成本

1. 500×20000=10000000次；×0.002=20000 s≈5.556 h。salt可與verifier同存並公開，目的是跨record隔開計算，不是保密key。
2. 不會。verifier已外洩時不經online檢查；2 ms仍是本題KDF成本。實際平行硬體/記憶體限制另定，本串行模型不宣稱實測攻擊時間。

檢查。 不同salt不使字典失效，只使預算表不易跨記錄共用。

OS15-E08　IDS 的 base rate

1. attack100、normal99900；TP90、FN10、FP999、TN98901；母體 precision=P(attack|alarm)=90/(90+999)=90/1089≈8.264%，也是期望 TP 除以期望告警數；它不一定等於有限樣本中隨機比值 TP/(TP+FP) 的期望。不是 TPR 的 90%。
2. 由πTPR≥(1−π)FPR，得FPR≤0.001×0.9/0.999≈0.000900901，約0.09009%。必須明列normal事件為分母。

檢查。 alarm正確率與真正率使用不同分母。

OS15-E09　Firewall 真正允許什麼

1. 依序deny、allow、deny、若符合既存state則allow。目的port相同不夠，source/destination zone、direction與state都要符合。
2. 仍能利用明列允許的DB5432通道；segmentation限制其他入口，不取消必要信任。DB須驗帳密/角色/查詢scope，且監控該合法通道的濫用。

檢查。 返回封包須符合state，不是任意聲稱established即可。

OS15-E10　Windows7 ordered DACL 與 MIC

1. request r：deny與remaining r不相交，allow移除r，DACL允許；MIC只有NWU不擋read，故本模型允許。request rw：MIC先以write-up拒，若單獨追DACL也會在deny G,w拒，不能據allow U,rw覆蓋。
2. 非canonical順序下allow先滿足全部remaining而DACL可成功，後面的deny不再掃；但MIC的write-up仍拒。因此不應說所有deny不管位置必覆蓋allow，也不應說DACL成功就必通過MIC。
3. 本普通DACL模型NULL無DACL則給存取；empty存在但無ACE，remaining無法清空而拒。最終還需mandatory policy等檢查。

檢查。 把每層判斷分開，不混成一條口訣。

參考資料與署名

Lin Cing，《作業系統》手寫筆記。 Silberschatz et al., Operating System Concepts, 9th ed., Ch. 15. RFC 5246. RFC 7568. Microsoft: DACL. Microsoft: MIC.

Lin Cing 原創教學整理，原創內容以 CC BY 4.0 授權。

https://github.com/xinhi6716/computer-science-self-study